Monthly Intelligence Dispatch

April 2021

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- Group-IB warned **Facebook** about a large-scale attack against Facebook Messenger users in **84** countries. **Group-IB Digital Risk Protection** specialists detected **5,700** fraudulent ads and about **1,000** fake Facebook profiles involved in the scheme.
- A threat group that specializes in targeted attacks has been using vulnerabilities in the Fortinet FortiOS operating system as a vector for penetrating the networks of government organizations.
- The personal data of about 533 million Facebook users is freely distributed on a popular hacker forum.
- According to Group-IB, a breach of the Swarmshop card shop resulted in information about sellers, buyers, and all stolen card data traded on the website being leaked.
- The Japanese videogame developer Capcom finished investigating a breach that resulted in its systems being infected and the personal data of thousands of users being stolen.
- Threat actors started using a malicious document builder named EtterSilent. Malicious documents created using it are distributed as attachments in spam and are yet poorly detected by VirusTotal antiviruses.
- The FBI arrested an individual for allegedly planning to “kill” about 70% of the Internet in a bomb attack targeting an Amazon Web Services (AWS) data center.

Facebook Messenger

Group-IB warned **Facebook** about a large-scale attack against **Facebook Messenger** users in **84** countries. **Group-IB Digital Risk Protection** specialists detected **5,700** fraudulent ads and about **1,000** fake Facebook profiles involved in the scheme, which was discovered by **Group-IB Digital Risk Protection** in late 2020: the threat actors distributed download links for a non-existent Facebook Messenger update. In April 2021, the number of fake Facebook posts inviting users to install "the latest Messenger update" reached **5,700**. The attack affected users in **84** countries, including **Russia** as well as regions such as **Europe**, **Asia**, **MEA**, and **the Americas**. To draw users' attention, the fraudsters registered accounts with names mimicking the real app (Messanger, Meseenger, Masssengar, and etc.) and used the official Facebook Messenger logo as their profile picture. The ads mentioned new features, both real and made-up; for instance, users were offered to download a non-existent Gold version of the app. The posts contained a short link created using the linktr.ee, bit.ly, cutt.us, cutt.ly, and rb.gy services. Following the link opened a phishing website with a fake authorization form. Victims risked losing access to their account as well as leaking other personal data, such as their phone numbers and email addresses. The data can then be used by threat actors for blackmail or spamming purposes or it can be sold on hacker forums.

Fortinet **FortiOS**	A well-trained cybercriminal group that specializes in targeted attacks has been using vulnerabilities in the Fortinet FortiOS operating system as a vector for penetrating the networks of government organizations. The campaigns were revealed by the Federal Bureau of Investigation (FBI) and the Cybersecurity and Infrastructure Security Agency (CISA). According to the published information, the APT group uses several exploits. In particular, the threat actors focus on three vulnerabilities: CVE-2018-13379, CVE-2020-12812, and CVE-2019-5591. In March 2021, the hackers attempted to find vulnerable servers that they could use to breach organizations' infrastructures. For instance, they scanned devices on ports 4443, 8443, and 10443. Government, commercial, and technology services networks were targeted. The attackers may also be targeting certain critical infrastructure sectors. Once access to the target networks has been gained, the attackers can establish a foothold for future malicious activities, such as exfiltrating confidential data or encrypting important information.
Facebook	The personal data of about 533 million Facebook users is freely distributed on a popular hacker forum. The compromised data fell into the hands of threat actors in 2019 as a result of a Facebook vulnerability. The leaked data includes full names; Facebook IDs; phone numbers; locations; email addresses; information about users' gender, occupation, country and city; account creation dates; etc. More than 32 million affected users are in the United States, 11 million are in the United Kingdom, 10 million are in Russia, and 6 million are in India.

Dom.rf

Some 104.8 records of Russians who applied for loans at the bank Dom.rf were put up for sale. The organization says the incident occurred because of a vulnerability in a remote application submission system. The leak affected over a year's worth of data (from February 2020 through March 2021). The price for the full database is $1,350. Individual strings can be bought for 20 cents (this year), 14 cents (second half of 2020), and 10 cents (first half of 2020). The database is believed to contain at least requested loan sums, phone numbers, and email addresses. Those who filled out the entire application form will have their full names, dates of birth, loan types and sums, passport details, taxpayer identification numbers, personal pension account numbers, residence addresses, occupation, and income levels in the database.

Swarmshop	According to Group-IB, a breach of the Swarmshop card shop resulted in information about sellers, buyers, and all stolen card data traded on the website being leaked. The website was compromised in March 2021. After a hacker tried to sell the database, users of the forum were asked to change their passwords. The dump contained 12,344 records of forum users, including Swarmshop admins', sellers' and buyers' nicknames, hashed passwords, contact details, and activity history. In total, the database revealed the records of 4 admins, 90 sellers, and 12,250 buyers of stolen data. All information about stolen bank cards that were traded on the website fell into the hands of threat actors. The dump contained data on 623,036 payment cards issued by US, Canadian, UK, Chinese, Singaporean, French, Brazilian, Saudi and Mexican banks. The database also contained 498 sets of online banking account credentials and 69,592 sets of US and Canadian social insurance numbers.
VISA	The global payments processor VISA warns that threat actors are increasingly deploying web shells on compromised servers to exfiltrate credit card information stolen from online store customers. Web shells are tools (scripts or programs) deployed by threat actors to gain and/or maintain access to hacked servers, remotely execute arbitrary code or commands, move laterally within a target's network, or deliver additional malicious payloads. Throughout the last year, VISA saw a growing trend of injecting JavaScript-based scripts known as JavaScript sniffers or web skimmers into online stores. Once deployed, sniffers allow threat actors to steal payment information submitted by buyers and exfiltrate visitors' personal data.

RevIL	The operators of the REvil ransomware attempted to blackmail Apple. The hackers claim that they obtained data about Apple products after breaching the Taiwanese company Quanta Computer, which is a leading laptop producer and one of the few original design manufacturers for Apple (products made by the company include Apple Watch, Apple Macbook Air, and Apple Macbook Pro). The threat actors put up a notice on their website addressing Quanta Computer saying that the company had to pay $50 million until April 27 or $100 million after that date. Otherwise, the REvil operators threatened to leak over a dozen design schematics of MacBook components. In a negotiation chat on REvil's payment site, REvil warned that “drawings of all Apple devices and all personal data of employees and customers will be published with subsequent sale” if Quanta did not begin negotiating a ransom.
CapCom	The Japanese videogame developer Capcom finished investigating a breach that resulted in its systems being infected and the personal data of thousands of users being stolen. The point of entry into the company’s network was an old backup VPN device. The targeted attack on Capcom involving the Ragnar Locker ransomware came to light in November last year. The breach resulted in some of the company’s services being unavailable, with the personal data of nearly 400,000 gamers being compromised.

FluBot

A botnet called FluBot infected over 60,000 devices, with 97% of the victims located in Spain. The botnet was first spotted at the start of the year by the security firm ThreatFabric. FluBot's sudden explosion in infection numbers can be explained by the presence of a clever worm-like mechanism inside its code that allows the malware's operator to upload the victim's address book to their command-and-control server and send SMS spam from it. There are currently more than 11 million phone numbers collected from infected devices, which accounts for 25% of the total population in Spain. The SMS messages contain various lures to trick recipients into clicking on a link. The links usually lead to hacked websites where the FluBot operators host their malware hidden inside APK files. If users download and install these apps — ignoring all of the operating system's warnings about installing apps from third-party sources — they get infected with FluBot.

ZHtrap

Security researchers discovered a botnet that turns infected IP cameras and routers into honeypots in order to ensnare new targets to further spread the infection. The malware that the botnet is based on (dubbed ZHtrap by Qihoo 360) deploys exploits or cracks passwords for accessing the Telnet service. Qihoo 360's analysis revealed that ZHtrap's code is based on Mirai and supports x86, ARM, MIPS and other major CPU architectures. Zhtrap can also get rid of rivals by killing non-whitelisted processes. The botnet uses a Tor command-and-control (C&C) infrastructure and communicates with the C&C server with the help of proxies, which it finds by requesting a DNS TXT record similar to the recently discovered Matryosh IoT bot. The new botnet's principal tasks are to conduct DDoS attacks and searching for vulnerable devices, which it finds by generating arbitrary IP addresses or using information collected using a honeypot. It can also function as a backdoor, allowing the operators to download and execute malicious modules.

HackBoss

Experts at Avast discovered a tool for stealing cryptocurrency. The tool is called HackBoss and it is distributed on Telegram disguised as free malware for beginners. The authors of HackBoss have already stolen more than $500,000 from wannabe hackers who have fallen for the trick. HackBoss is usually disguised as paid hacking tools, mostly related to cracking passwords for bank accounts, dating websites, and social media. Each promotion post is accompanied with a detailed description to make it look legitimate. The HackBoss Telegram channel publishes about nine such messages every month, with each message having over 1,300 views and over 2,800 people subscribed to the channel (according to Telemetrio). The malware is packaged in a ZIP file with an executable that launches a simple user interface. Despite the available options, the sole purpose is to decrypt and execute the cryptocurrency-theft malware on the victim's system. This happens when clicking on any button in the fake interface. The action can also help HackBoss persist in the system by making changes to the registry or adding a scheduled task that runs the payload every minute.
Avast analysts collected a list of more than 100 cryptocurrency wallet addresses belonging to the HackBoss authors. More than 560,000 dollars' worth of various cryptocurrencies has been transferred to these wallets since November 2018. Not all the funds came from cryptocurrency-stealing malware, however: some wallets were connected with another type of fraud, which involved tricking victims into buying fake software.
The HackBoss authors also promote their fake hacking tools outside the Telegram channel, although it remains the main distribution path. For instance, the hackers have a blog (cranhan.blogspot[.]com) that advertises fake tools and provides promo videos. In addition, ads promoting the malware are published on public forums.

EtterSilent

Threat actors started using a malicious document builder named EtterSilent. Malicious documents created using it are distributed as attachments in spam and are yet poorly detected by VirusTotal antiviruses. Ads promoting the maldoc builder have been published on underground forums since at least mid-2020, boasting features like effectively bypassing Windows Defender, Windows AMSI (Antimalware Scan Interface) and the security filters of popular email services, Gmail included. Analysis by Intel 471 revealed that EtterSilent can create two types of fake Microsoft Office documents: with an exploit or a malicious macro. Among the exploits in the builder's arsenal are CVE-2017-8570, CVE-2017-11882, and CVE-2018-0802, the use of which is pointless on Windows with the latest version of Microsoft Office. Generally, the email attackers favor the malicious macro option as it is compatible with any version of Microsoft Office supported by EtterSilent (2007-2019). The potential victim only needs to be convinced to activate the appropriate function; such documents are still distributed disguised as DocuSign or DigiCert documents. Interestingly, because it makes use of Excel 4.0 XML macros, EtterSilent doesn't rely on the Visual Basic for Applications (VBA) programming language, which is often seen with malicious macros.

Android.Joker

Multifunctional Android.Joker Trojans, which subscribe users to paid mobile services, were discovered on AppGallery, the official app store for Huawei devices. A total of ten modifications of these Trojans were discovered, with over 538,000 users having installed them. The modifications were spread under the guise of harmless apps that, when launched, worked as users would have expected. This technique allows attackers to stay below the radar for prolonged periods of time and infect as many Android devices as possible. For victims, the Trojans acted like virtual keyboards, a camera app, a launcher, an online messenger, a sticker collection, coloring programs, and a game. Eight of these apps were distributed by the developer Shanxi kuailaipai network technology co., ltd, while the other two by the developer 何斌.

Arrests and sentences

Seth Pendley

The FBI arrested a Texas man for allegedly planning to “kill” about 70% of the Internet in a bomb attack targeting an Amazon Web Services (AWS) data center. Seth Aaron Pendley, 28, was charged for attempting to destroy an AWS data center in Ashburn, Virginia, using C-4 plastic explosives that he tried to buy. Pendley believed the operation would completely disrupt 70% of the Internet. The FBI learned about the suspect's plans in January when he revealed his plot on MyMilitia, a forum, using the handle Dionysus. In late January, Pendley started using Signal, a messaging app, to communicate with a source who introduced Pendley to an undercover FBI employee posing as an explosives supplier. In February, Pendley shared a hand-made map of Amazon's Virginia-based AWS data center. The suspect was arrested by the FBI after placing what he believed to be explosive devices into his car, following a demonstration from the "explosives supplier" on how to arm and detonate them.

Wyatt Travnichek

The US Department indicted Wyatt Travnichek, a 22-year-old Kansas resident, for tampering with a public water system. The authorities say Travnichek gained unauthorized access to the Ellsworth County Rural Water District’s computer system and “performed activities that shut down the processes at the facility which affect the facilities cleaning and disinfecting procedures with the intention of harming the Ellsworth Rural Water District No. 1.” Travnichek worked for the water district from January 2018 until he resigned in January of 2019. The court documents do not specify whether Travnichek’s attack was successful or if the hack was detected before it was too late, but the law enforcers say that his actions threatened the safety and health of an entire community. If found guilty, Travnichek faces up to 5 years in federal prison and a fine up to $250,000 for reckless damage to a protected computer during unauthorized access as well as up to 20 years in federal prison and a fine up to $250,000 for tampering with a public water system.

Arrests and sentences

FIN7

A US court sentenced Fedir Hladyr, a Ukranian national, to ten years in prison for his involvement in the activities of the FIN7 hacking group. Hladyr, 35, (aka das and AronaXus) was arrested (together with two other FIN7 members: Dmytro Fedorov and Andrii Kolpakov, also Ukrainian nationals, who are yet to be sentenced) in January 2018 in Dresden, Germany, and was extradited to the US in July that year. The Department of Justice referred to him as the group's systems administrator who was responsible for maintaining FIN7 servers and communication channels. He also acted as a manager and delegated tasks to other members of the group. According to law enforcers, from 2013 through 2018, FIN7 attacked more than 100 companies and organizations in the US and breached thousands of systems. It was reported that in the US alone, the hackers had stolen more than 15 million payment cards from over 6,500 point-of-sale terminals. The data was then sold on the dark web. According to the FBI, the hackers' victims include companies such as Chipotle Mexican Grill, Chili's, Arby's, Red Robin, and Jason's Deli. The group had over 70 members organized into business units and teams. Some were hackers, others developed malware, others crafted malicious emails. Speaking to the court, Hladyr said that he regretted working at Combi Security, a fake cybersecurity company created by FIN7 hackers to disguise some of their attacks as penetration testing. Hladyr said he had "ruined years of my life and put [his] family through great risk and struggle."

Forecasts and warnings

- Group-IB recommends that users download applications and updates on official app stores only and trust company accounts that send out ads only if they are verified to avoid falling victim to fraud. We advise you to be cautious about short links. If you visit a website where you are asked to be authorized to log in to Facebook Messenger, check the domain name: fraudsters typically register domain names that look similar to the targeted brand. Log in on the official website and apps only!
- Major banks have enhanced the security of their applications: they improved fault tolerance by transitioning to the microservice architecture and reduced the number of standard vulnerabilities (XSS, SQLi, RCE). However, the number of logical vulnerabilities, which can result in money being stolen, hackers obtaining sensitive information, and, as a result, a denial of service on the bank side, has risen. Hackers' aim today is not necessarily to completely compromise banking application systems; rather, to exploit logical vulnerabilities.
- Trends that will define the evolution of the cybersecurity market in 2021 are: rethinking approaches to cybersecurity for hybrid work; increasing the share of cybersecurity in businesses' IT budgets; using behavioral analysis for data protection; and developing automation tools and expanding analytical skill sets. Cybersecurity is becoming a priority that is connected with the business strategy aspect — minimizing damage to IT resources.
- If an enterprise has network segments that should be isolated from other networks and the Internet, it is necessary to regularly check whether that is indeed the case, for example, by periodic security assessments and penetration tests.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com